SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking **COURSE CODE: ITA1412**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Social Engineering Simulation

Questions

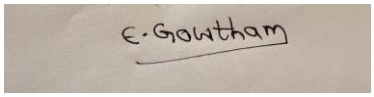
1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**

2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks**.(20 Mark).**

3. Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.**(10 Marks)**

Code of Conduct:

I Enamala Gowtham /192311190 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: 

RUBRICS FOR CALCULATION

Social Engineering Simulation

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	Applies relevant concepts with minor errors and recommends suitable countermeasures.	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures.
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

Question 1: OSINT-Based Email Enumeration Using the Harvester

1. Aim

To perform Open-Source Intelligence (OSINT) reconnaissance on the target domain tesla.com using theHarvester in Kali Linux to identify publicly available email addresses, subdomains, hostnames, and IP addresses, and analyze the associated social engineering risks.

2. Objectives

- To understand the concept of OSINT and email enumeration.
- To collect publicly available information about a target domain.
- To categorize discovered email addresses according to likely organizational roles.
- To identify possible spear-phishing, credential-harvesting, and impersonation risks.
- To recommend security controls that reduce information leakage.

3. Introduction

Open-Source Intelligence (OSINT) is the process of collecting and analyzing information from publicly available sources. In cybersecurity, OSINT helps security analysts understand an organization's external exposure without requiring direct access to its internal network.

Email enumeration is the process of identifying email addresses associated with a domain through permitted public sources. Subdomain and hostname discovery can reveal publicly visible infrastructure that an organization may need to review.

TheHarvester is a reconnaissance tool available in Kali Linux. Depending on the installed version and configured data sources, it can collect information such as email addresses, domains, hostnames, and related infrastructure details.

OSINT is useful for authorized security assessments because it helps organizations discover information that could be misused by attackers.

4. Tools and Requirements

Tool	Purpose
Kali Linux	Security testing environment
theHarvester	Collect publicly available reconnaissance data
Terminal	Execute commands
Internet connection	Access supported public data sources
Text editor	Record findings and prepare the report

5. Procedure and Commands

Step 1: Open Kali Linux

Start Kali Linux and open the terminal.

Step 2: Check theHarvester availability

theHarvester -h

This displays the supported command options and data sources.

Step 3: Perform a public-source search

theHarvester -d tesla.com -b crtsh

Here:

- -d tesla.com specifies the target domain.
- -b crtsh selects the Certificate Transparency search source.

The command demonstrates collection from a public source. The results depend on the tool version and available source data.

Step 4: Save the results

theHarvester -d tesla.com -b crtsh -f tesla_report

If the installed version supports the -f option, the results are saved to a report file. Use theHarvester -h to confirm the correct syntax.

Step 5: Record the findings

Record the actual output in the following table.

Information	Finding
Target domain	tesla.com
Email addresses	Enter verified results
Subdomains	Enter discovered results
Hostnames	Enter discovered results
IP addresses	Enter resolved results
Data source	crt.sh
Date of assessment	Enter assessment date

Important: These are report fields, not verified live findings. Do not invent email addresses, hostnames, or IP addresses to fill the table.

6. Categorization of Email Addresses

Collected addresses can be classified by their published purpose or available organizational context. The categories below are examples, not confirmed Tesla accounts.

Category	General purpose	Possible security risk
Support	Customer assistance	Fake support requests
Sales	Sales enquiries	Fraudulent quotations
Human Resources	Recruitment and employment	Fake job offers
Administration	General office operations	Impersonation of staff
Technical Team	IT and technical support	Fake password-reset requests

An email address alone does not prove the identity, job title, or department of its owner. Classification should be supported by reliable public evidence.

7. How Attackers Could Misuse OSINT

A. Spear-phishing

Spear-phishing is a targeted phishing attack directed at a particular person or department. Public information can help an attacker create a message that appears relevant to the recipient.

For example, a fraudulent message might pretend to be about a recruitment process or an IT security notification. An employee who trusts the message may open an unsafe link or attachment.

B. Credential harvesting

Credential harvesting attempts to trick users into disclosing login details through a fraudulent website or message. Publicly visible employee contact information can help attackers select targets for these attempts.

C. Impersonation attacks

Attackers may pretend to be employees, managers, vendors, or technical support personnel. They may use publicly available organizational information to make false requests seem legitimate.

D. Infrastructure reconnaissance

Subdomains and hostnames can reveal which services or systems are publicly visible. Security teams can use this information to identify unnecessary exposure and prioritize reviews.

E. Business email compromise

Attackers may use organizational information to create convincing messages involving invoices, payments, or business requests. Verification procedures are important even when a message appears to come from a known contact.

8. Risk Assessment

Threat	Likelihood	Potential impact	Priority
Targeted phishing	Medium	High	High
Credential theft	Medium	High	High
Employee impersonation	Medium	Medium to High	High
Exposure of unnecessary subdomains	Depends on exposure	Medium to High	Review required

Fraudulent business requests	Medium	High	High

These ratings are illustrative. A real assessment should assign likelihood and impact based on verified evidence, existing controls, and the organization's risk criteria.

9. Countermeasures

1. Limit public information: Publish only necessary employee and departmental contact details.
2. Enable MFA: Require multi-factor authentication for important accounts.
3. Configure email authentication: Implement SPF, DKIM, and DMARC appropriately.
4. Conduct awareness training: Teach employees to identify suspicious messages and verify unusual requests.
5. Review subdomains: Maintain an inventory of public-facing hostnames and remove unnecessary exposure.
6. Apply least privilege: Give users only the permissions required for their jobs.
7. Monitor suspicious activity: Review authentication logs and investigate unusual sign-in patterns.
8. Establish reporting procedures: Provide a simple way for employees to report suspected phishing.
9. Verify sensitive requests: Confirm payment changes and confidential requests through a separate trusted channel.
10. Perform regular assessments: Repeat authorized OSINT reviews to identify newly exposed information.

10. Result

The assessment procedure demonstrates how theHarvester can support public-information reconnaissance. The collected evidence can help identify information leakage and potential social engineering risks. Actual findings should be documented and evaluated before recommending corrective actions.

Question 2: Phishing Awareness Simulation Using GoPhish

1. Aim

To conduct an authorized phishing-awareness simulation using GoPhish and dummy employee accounts, measure user interactions, and recommend methods to improve organizational phishing awareness.

2. Objectives

- To understand phishing attacks and their impact.
- To create a simulated phishing email.
- To conduct a controlled campaign using dummy accounts.
- To measure delivery rate, open rate, and click rate.
- To evaluate awareness and recommend preventive measures.

3. Introduction

Phishing is a social engineering technique in which an attacker uses deceptive emails, messages, or websites to trick people into revealing confidential information or performing unsafe actions.

GoPhish is an open-source phishing simulation platform used by security teams to conduct authorized awareness exercises. It provides features for managing test recipients, email templates, campaigns, landing pages, and campaign reports.

A phishing simulation helps organizations understand how users respond to suspicious messages. It can also identify areas where additional training and technical protection are required.

The simulation should use dummy accounts or explicitly authorized participants, and it should never collect real passwords.

4. Tools Required

Tool	Purpose
GoPhish	Manage phishing-awareness campaigns
Kali Linux or supported OS	Run the testing environment
Dummy email accounts	Test message delivery and interactions
Test email server	Send authorized simulation emails
Web browser	Access the dashboard and training page
Spreadsheet	Calculate and analyze results

5. Procedure

Step 1: Start GoPhish

Install GoPhish using its official installation instructions for your operating system. Start the application and access the local administrator dashboard according to its configuration.

Step 2: Create a recipient group

Create a group containing dummy employee accounts. Verify that the accounts are controlled by the lab and are permitted to receive test emails.

Step 3: Create an email template

Prepare an awareness-training email that represents a common phishing scenario.

Sample email template

Dear Employee,

Our organization is conducting a cybersecurity awareness exercise to improve email security.

Please review the security awareness information available through the authorized training portal.

Thank you,

IT Security Awareness Team

For a controlled simulation, the message can contain a test link that leads to a training page explaining phishing warning signs.

Step 4: Configure the sending profile

Configure the authorized lab email server and verify that the sender identity is appropriate for the exercise. Test delivery with a single dummy account before starting the campaign.

Step 5: Create the landing page

Create a landing page that explains common phishing indicators, such as suspicious links, unexpected requests, and sender-address mismatches.

Do not request or store real credentials.

Step 6: Create and launch the campaign

Select the dummy recipient group, email template, sending profile, and training page. Launch the campaign only after verifying authorization and the recipient list.

Step 7: Monitor the results

Observe the campaign dashboard for:

- Emails sent and delivered.
- Email opens, where tracking is enabled.
- Unique link clicks.
- Failed deliveries.
- User reports, if reporting data is available.

Step 8: Generate the report

Export or record the available results and calculate the performance metrics.

6. Performance Metrics and Formulas

A. Delivery Rate

The percentage of sent emails successfully delivered.

$$\text{Delivery Rate} = \frac{\text{Delivered Emails}}{\text{Emails Sent}}\times100$$

B. Open Rate

The percentage of delivered emails recorded as opened.

$$\text{Open Rate} = \frac{\text{Emails Opened}}{\text{Delivered Emails}}\times100$$

Open tracking may be inaccurate because of email privacy features, image blocking, or automated scanners.

C. Click Rate

The percentage of delivered emails associated with a unique tracked click.

$$\text{Click Rate} = \frac{\text{Unique Clicks}}{\text{Delivered Emails}}\times100$$

The denominator should be stated clearly in the report because different organizations may use different conventions.

7. Sample Campaign Results

The following is an illustrative example for 100 test emails, not actual GoPhish output.

Parameter	Value
Total emails sent	100
Emails delivered	95
Emails opened	60
Unique clicks	20
Delivery rate	95%
Open rate	63.16%
Click rate	21.05%

Sample calculations

Delivery rate:

$$\frac{95}{100}\times100=95\%$$

Open rate:

$$\frac{60}{95}\times100=63.16\%$$

Click rate:

$$\frac{20}{95}\times100=21.05\%$$

8. Analysis of Results

Delivery rate: A high delivery rate indicates that most test messages reached the intended mailboxes. Delivery failures may result from incorrect addresses, server problems, or email filtering.

Open rate: A high open rate indicates that many messages were recorded as opened. However, this does not necessarily mean recipients trusted the message or read its content.

Click rate: A high click rate may indicate that the message successfully attracted attention and that recipients need more practice identifying suspicious links.

Overall interpretation: In the illustrative example, 20 of the 95 delivered emails generated unique clicks. This result can be used as a baseline for future training exercises.

9. Recommendations

1. Conduct phishing-awareness training regularly.
2. Teach employees to inspect sender addresses and URLs.
3. Enable multi-factor authentication.
4. Use secure email gateways and anti-phishing filters.
5. Provide a clear procedure for reporting suspicious emails.
6. Use simulated exercises to measure progress over time.
7. Train employees to verify unexpected requests through trusted channels.
8. Avoid collecting actual passwords during simulations.
9. Review campaign results and provide constructive feedback.
10. Compare results across repeated exercises to evaluate improvement.

10. Result

The GoPhish procedure demonstrates how an authorized phishing-awareness campaign can measure email delivery, opens, and clicks. The resulting report can help identify awareness gaps and improve employee training and email security controls.

Question 3: Nmap Aggressive Scan and Social Engineering Risk Analysis

1. Aim

To perform an authorized Nmap aggressive scan on scanme.nmap.org, examine discovered network services, and explain how reconnaissance information could be misused in social engineering attacks against an IT support team.

2. Objectives

- To understand network reconnaissance.
- To learn the purpose of Nmap aggressive scanning.
- To identify open ports and service-version information.
- To understand the relationship between technical information and social engineering.
- To recommend suitable defensive controls.

3. Introduction

Nmap, or Network Mapper, is a network exploration and security auditing tool. It helps administrators and security analysts discover hosts, identify open ports, detect services, and perform certain forms of operating-system detection.

An open port indicates that a service is accepting connections on that port. It does not automatically mean that the service is vulnerable.

Nmap's aggressive scan option, -A, enables several detection features, including operating-system detection, version detection, script scanning, and traceroute. The information collected helps administrators understand their exposed network services.

The assessment must follow the target's published scanning rules and permitted scope.

4. Tools Required

Tool	Purpose
Kali Linux	Testing environment
Nmap	Network scanning and service detection
Terminal	Execute commands
Text editor	Document findings
Report template	Record risks and recommendations

5. Procedure and Commands

Step 1: Open the terminal

Start Kali Linux and open a terminal.

Step 2: Verify Nmap installation

nmap --version

This displays the installed version of Nmap.

Step 3: Perform the aggressive scan

nmap -A scanme.nmap.org

Use this command only within the host's authorized scanning scope.

Step 4: Understand the command

- nmap starts the network scanning tool.
- -A enables multiple detection features, including service/version detection, OS detection, script scanning, and traceroute.
- scanme.nmap.org specifies the target hostname.

Step 5: Save the output

nmap -A -oN nmap_report.txt scanme.nmap.org

The -oN option saves the scan output in normal text format.

Step 6: Analyze the output

Record the actual information returned by the scan.

Parameter	Details to record
Target	scanme.nmap.org
Host status	Up or down
Open ports	Actual ports reported
Services	Service names identified
Service versions	Detected versions, if available
OS details	Detection result, if available
Potential risks	Items requiring further verification

Do not assume that a port is open or a particular operating system is present without evidence from the scan.

6. Attack Methodology: Social Engineering Scenario

The following is a defensive scenario showing how an attacker might misuse technical reconnaissance information.

Step 1: Information gathering

An attacker collects publicly available information about an organization's technology and exposed services.

Step 2: Target selection

The attacker identifies the IT support team as a possible target because its members may handle technical incidents and account-access requests.

Step 3: Impersonation

The attacker may pretend to be a technical employee, software vendor, or support representative.
Knowledge of common service names can make the false identity appear more believable.

Step 4: Deceptive communication

The attacker may send a fraudulent message claiming that a service needs urgent maintenance or an account requires verification.

Step 5: Potential impact

If an employee trusts the fraudulent request, the attacker may obtain confidential information, cause an unauthorized account change, or gain access to a protected resource.
The scan itself does not establish that an IT support team is vulnerable. A successful social engineering attack also depends on human behavior, existing controls, and the circumstances of the interaction.

7. Risk Analysis

Risk	Possible impact	Priority
Unnecessary open ports	Increased external exposure	Review
Outdated services	Possible exploitation of known vulnerabilities	High if verified
Excessive technical disclosure	More convincing impersonation	Medium
Weak account verification	Unauthorized account changes	High
Insufficient employee awareness	Increased phishing risk	High

These priorities are preliminary. The final risk rating should be based on verified findings and the organization's risk-assessment method.

8. Defensive Recommendations

1. Close unnecessary ports: Disable services that are not required.
2. Patch systems: Keep operating systems and applications updated.
3. Use firewalls: Restrict access to administrative and sensitive services.
4. Apply least privilege: Limit access to only the resources required for each role.
5. Verify identities: Confirm unusual IT support requests through an independent trusted channel.
6. Use MFA: Protect accounts with multi-factor authentication.
7. Monitor network traffic: Investigate suspicious connections and repeated scanning activity.
8. Train employees: Teach staff to recognize impersonation and fraudulent security alerts.
9. Review exposed services: Conduct periodic authorized vulnerability assessments.
10. Maintain incident-response procedures: Provide clear steps for reporting and investigating suspicious activity.

9. Result

The Nmap procedure demonstrates how network reconnaissance can identify exposed services and provide information for security reviews. Combining secure network configuration, patch management, identity verification, and employee awareness helps reduce technical and social engineering risks.

Final Conclusion

Social engineering simulation is an important part of ethical hacking because attackers may combine public information, network reconnaissance, and human deception to target an organization.

- Question 1: theHarvester demonstrates OSINT collection and helps identify possible information-leakage risks.
- Question 2: GoPhish helps evaluate phishing awareness using controlled campaigns and measurable results.
- Question 3: Nmap helps identify exposed network services and supports defensive risk analysis.

Organizations can reduce these risks through MFA, secure email configurations, regular patching, least-privilege access, employee awareness training, and continuous security monitoring.